第 9 章 数据与云计算安全

本章学习要点：

- 掌握数据备份相关概念及实现技术；
- 掌握云计算相关概念；
- 熟悉云计算体系结构；
- 熟悉云计算面临的安全威胁；
- 了解当前云计算安全主要保护技术。

9.1 数据安全概述

数据安全通常有两方面的含义：①数据本身的安全，主要指采用现代密码算法对数据进行主动保护；②数据的防护安全，主要是采用现代信息存储手段对数据进行主动防护，如通过磁盘阵列、数据备份和异地容灾等手段保证数据的安全。

在中小企业服务平台建设中，只有服务平台在保证自身数据安全的前提下，才能使中小企业积极主动参与到云平台建设中，实现信息流转是提高服务工作办理效率的目的。作为一个典型的政务信息管理系统，中小企业平台在数据安全方面必须提供一种主动的防护措施，必须在数据收集、数据存储、数据处理与交换、数据传输以及数据销毁等不同阶段依靠可靠、完整的安全体系与安全技术来保证数据内容的安全。简单来讲，有关数据安全的内容可以简化为在数据全生命周期中确保数据的机密性、完整性和可用性。

本章内容将主要从数据的防护安全角度介绍数据备份与恢复，并结合新的计算环境，讲述云环境下数据的存储管理技术和云数据的安全防护技术等。

9.2 数据备份与恢复

在当今复杂的计算机系统应用环境中，每天都可能面对各种自然灾害和人为灾难的发生，对于各种关键性业务来说，即使是几分钟的业务中断和数据丢失所带来的损失也是难以估量的。在信息时代，业务的发展离不开信息系统，而构成信息系统平台的硬件与软件都不是系统的核心价值，只有存储于计算机中的数据才是真正的财富。企业自身发展中的众多信息和数据如何保护，对保证业务的持续性至关重要。因此，数据备份越来越得到企业的重视。在数据变得越来越重要的今天，一套稳定的备份还原系统成为保证系统正常运行的关键组件。数据备份不仅仅是数据的保存，还包括数据保护、备份策略等。

数据恢复就是将数据恢复到事故之前的状态。数据恢复总是与备份相对应，实际上可以看成备份操作的逆过程。备份是恢复的前提，恢复是备份的目的，无法恢复的备份是没有意义的。因此，在信息系统安全中，数据恢复是不可忽略的，而事实上，一般的企业往往是在遭受灾

难以后或者在灾难发生时才考虑到数据恢复策略，此时已经无法挽回损失。因此，数据恢复技术是一种预防性的措施。数据灾难恢复工作对信息系统的建设具有举足轻重的作用，有关研究表明，2020年，在调查的17个国家和地区的524家企业中，因数据灾难所造成的损失平均为386万美元，52%来源于恶意攻击，其中医疗行业受影响最为严重，损失较上一年增长了10%。由于服务中断带来的损失巨大，美国在20世纪70年代就有了灾备的概念和服务企业，经过多年的发展已经形成了专业的灾备市场和完善的灾难恢复系统。从2004年10月开始，国务院信息办就开始着手组织中国人民银行、信息产业部等8个国家重要信息系统主管部门起草我国的信息系统灾难恢复有关标准，并成立《重要信息系统灾难恢复指南》起草组。在参考有关国际标准的前提下，结合我国具体的信息安全保障国情，于2005年4月正式出台了《重要信息系统灾难恢复指南》。2007年7月，《重要信息系统灾难恢复指南》正式升级成为国家标准《信息系统灾难恢复规范》(GB/T 20988—2007)。工业和信息化部门还于2019年还推出了《信息系统灾难恢复能力要求》(YD/T 3485—2019)，并于2020年1月开始正式实施。

数据备份和恢复技术实质上就是根据管理规划，将重要数据建立副本，将数据副本保存到与原始数据不同的存储位置，当原始数据丢失或破坏时，按照一定的恢复策略将数据备份恢复成原始数据的过程。数据备份是数据恢复的前提条件，数据恢复是数据备份的最终目的，两个过程协同工作最终能保障数据存储的安全。

9.2.1 数据备份需求

在网络化时代，数据信息面临着各种风险，数据安全十分重要，而数据的备份和恢复是数据安全的有力保障。顾名思义，数据备份就是将数据以某种方式加以保留，以便在系统遭受破坏或其他特定情况下，重新恢复的一个过程。例如，在日常生活中，人们常常为自己家的门锁多配几把钥匙，这就是备份的一个具体思想体现。在复杂的计算机信息系统中，数据备份不仅仅是简单的文件复制，在多数情况下指数据库的备份。数据库的备份是制作数据库结构和数据的复制，以便在数据库遭受破坏时能够迅速地恢复数据库系统。

长期以来，对企业而言，建立一套可行的备份系统相当困难，主要是高昂的成本和技术实现的复杂度。鉴于此，从可行的角度来说，一个数据备份与恢复系统必须有良好的性价比。

对一个相当规模的系统来说，让系统进行完全自动化的备份是对备份系统的一个基本要求。除此以外，数据备份系统还需要重点考察机器CPU占用、网络带宽占用、单位数据量的备份等。系统资源的开销和备份过程给系统带来的影响是不可小觑的，在实际环境中，一个备份作业运行过程中，可能会占用中档小型服务器60%的CPU资源，而一个未妥善处理的备份日志文件，可能会占用大量的磁盘空间。这些都来自真实的运行环境，而且属于普遍现象。由此可见，备份系统的选择和优化工作也是一个至关重要的任务。

即使在科技发达的今天，数据备份的价值仍然不能忽略，数据备份仍然作为防止数据丢失的首要选择。在日常生活中，大多数的文档数据会存储的信息系统中，因此，如果没有数据备份系统，当信息系统崩溃或损坏时，数据会全部丢失，无法恢复。例如，当一个用户在网络上进行一宗大型交易时，计算机或银行服务器崩溃，导致相关的文件丢失，并最终造成交易数据的丢失。在这个场景中，除非交易双方用其他的方式可以证明他们发生了交易，不然，数据丢失会给双方带来巨大的损失。

在信息系统中，任何东西都无法取代原始数据的地位，因此，在数据丢失的情况下，为能使数据快速高效地恢复，数据备份是最好的也是首先选择的技术。对于任何一个组织，没有对数

据进行备份是非常不利的。因为，在如今网络环境下，每一次数据传输都要经过复杂的网络环境，经过大量的网络设备，一旦中途有设备崩溃，造成数据丢失，用户很难找到证据证明自己传输了这条数据。

另外，数据备份可以保证用户数据的可用性和完整性。当数据库系统崩溃并丢失所有数据后，信息管理系统可以利用备份的数据进行恢复，从而使数据重新变得可用，因此保证了数据的可用性。而当数据完整性遭到破坏时，信息管理系统仍然可以通过数据恢复系统将备份的数据恢复。由此可见，数据备份是信息系统中不可或缺的一个重要组成部分。

数据备份的根本目的是重新利用，这也就是说，备份工作的核心是恢复，一个无法恢复的备份，对于任何系统来说都是毫无意义的。因此，备份数据的真正价值是能够安全、高效又方便地恢复数据。



9.2.2 数据备份类型

根据不同的标准，数据备份有不同的类型。例如，数据备份根据备份的位置可分为本地备份和异地备份；根据备份的层次可分为硬件冗余和软件冗余；根据备份的自动化程度可以分为高度自动化备份、按计划自动化备份和人工备份。本节着重介绍按照如下标准划分的两种数据备份类型。

1. 根据数据备份的状态分类

按照备份的状态，数据备份可以分为物理备份和逻辑备份。

（1）物理备份。指将实际物理数据库文件复制出另一份备份的形式，通常所说的冷备份、热备份都属于物理备份。具体而言，冷备份，也称脱机备份，指以正常的形式关闭数据库，并对数据库的所有文件进行备份，在恢复期间，用户无法访问数据库，需要花费专门的时间来进行。热备份，也称联机备份，指在数据库运行的情况下进行的备份，用户可以对数据库进行正常的操作，也可以是通过数据库系统的复制服务器，连接正在运行的数据库服务和热备份服务器，将主服务器上的数据修改传递到备份数据库服务器中，保证两个服务器的同步，其实质是一种实时备份，两个数据库分别运行在不同的服务器上，且每个数据库的文件都写到不同的数据设备中。

（2）逻辑备份。和物理备份不同，其不是将数据库的所有文件都进行备份，而是将某个数据库的记录都读取再写入一个文件中，这是经常使用的一种备份方式。

2. 根据数据备份的数据量分类

按照备份的数据量，数据备份可以分为完全备份、增量备份、差分备份。

（1）完全备份，指对系统中所有的数据进行备份，特点是备份时间最长，但恢复时间最短，效率最高，操作最方便，也是最可靠的一种备份方式，因此，一般在周末或夜里用户较少时进行备份。

（2）增量备份，指只对上次备份后产生变化的数据进行备份，特点是备份时间短，占用的空间也比较少，但是恢复的时间比较长。

（3）差分备份，指只对上次进行完全备份后产生变化的数据进行备份，特点是备份时间较长，占用空间较多，但是恢复时间较短。

完全备份、增量备份及差分备份之间的关系如图 9.1 所示。

在实际备份应用系统中，通常使用这三种不同的备份技术结合实现数据备份，这里介绍两种结合方式。

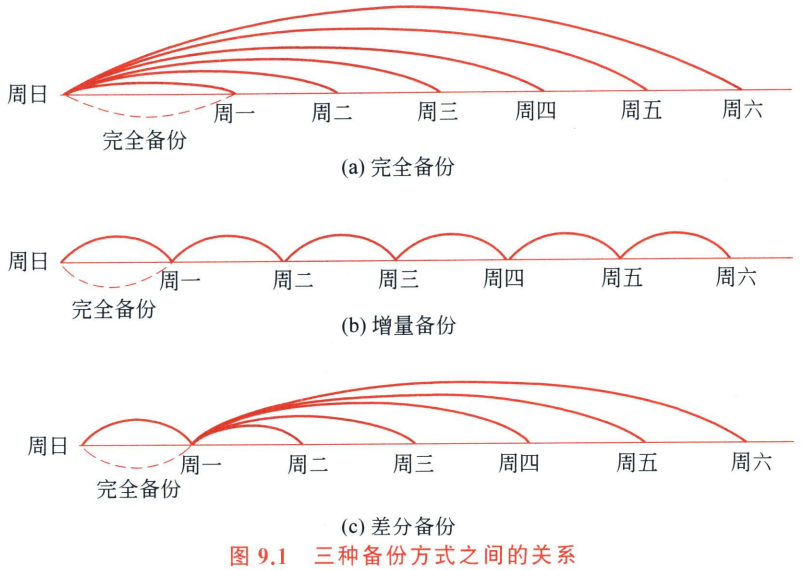


图 9.1　三种备份方式之间的关系

(1) 完全备份和增量备份的结合。完全备份加增量备份源于完全备份，不过减少了数据移动，其思想就是较少使用完全备份，如图 9.2 所示。比如，在周日晚上进行完全备份(此时对网络和系统的使用最小)，在其他 6 天(周一到周六)则进行增量备份。增量备份会对系统进行查询，当查询到从昨天开始，哪些数据发生了变化之后，会把这些变化的数据复制到当天已经备好的磁盘上。在周一到周六使用增量备份，能保证只移动那些在最近 24 小时内改变的文件，而不是所有的文件。由于只对较少的数据进行移动和存储，所以增量备份减少了对磁盘阵列的需求。对于用户来讲，则可以在一个高度自动化的系统中使用更加集中的磁盘阵列，以便允许多个客户机共享存储资源。

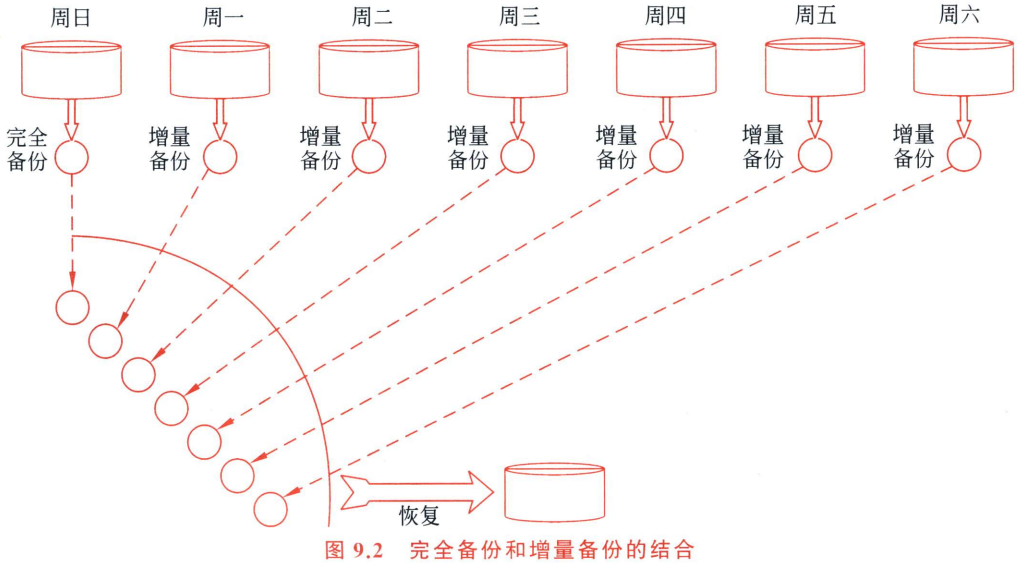


图 9.2　完全备份和增量备份的结合

完全备份＋增量备份的明显不足之处在于恢复数据较为困难。完整的恢复过程首先需要恢复上周日备份的完全备份数据，然后将增量备份的数据恢复并覆盖掉完全备份中对应的数据。因此，该策略最坏的情况就是要设置 7 个磁盘整理，如果每天都有数据修改，则需要恢复

7次才能将所有的数据恢复到最新。

（2）完全备份和差分备份的结合。为了解决完全备份＋增量备份方法中数据恢复困难的问题，产生了完全备份＋差分备份的方法。此时，数据差异性成为备份过程中要考虑的问题。在采用增量备份时，需要查询自昨天以来，哪些数据发生了变化；而采用差分备份的方式，需要查询自完全备份以来，哪些数据发生了变化。对于完全备份后的第一次备份，因为周日刚对数据系统进行了完全备份，所以在周一进行备份时，这两种方法备份的数据是一样的。但是到了周二进行备份时，增量备份只需要备份从昨天（周一）开始发生了变化的数据，而差分备份则需要查询自上次完全备份（周日）后发生变化的数据，并把这些变化的数据备份到磁盘阵列中。到了周三时，增量备份还是只需要备份过去24小时发生变化的数据，差分备份则需要备份过去72小时发生变化的数据。

尽管差分备份比增量备份移动和存储的数据更多，但是在进行数据恢复时就比较简单。在完全备份＋差分备份方法下，完整的恢复过程包括首先对上周日完全备份的数据进行恢复，然后再将最新差分备份的数据进行恢复并覆盖到已恢复的完全备份的数据中，如图9.3所示。

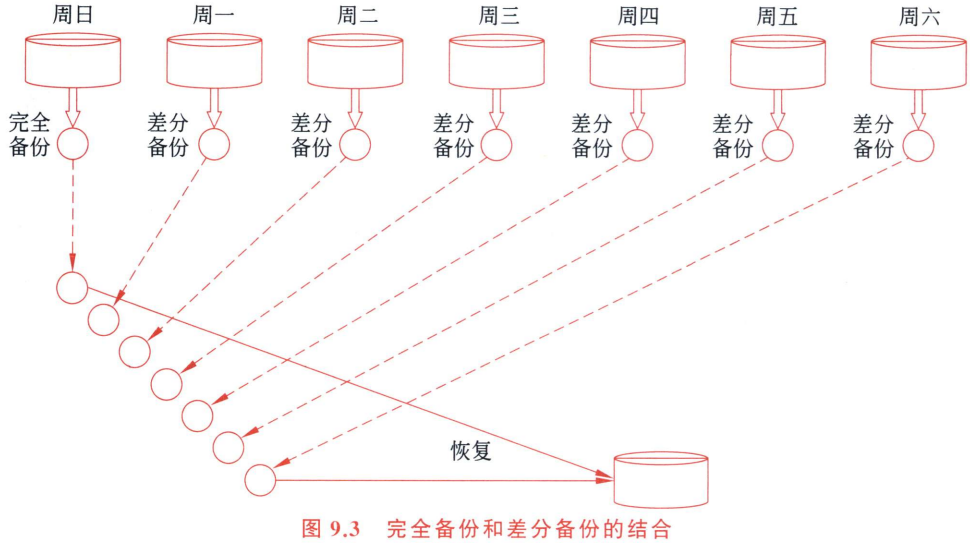


图9.3 完全备份和差分备份的结合

9.2.3 数据容灾技术

数据备份是数据高可用的最后一道防线，其目的是使系统数据崩溃时能够快速地恢复数据。然而，数据备份只是容灾方案中的一种，而且它的容灾能力非常有限，因为传统的备份只是采用数据内置的或外置的磁盘设备进行冷备份，备份的磁盘同时也放在机房中统一管理，一旦整个机房出现灾难，如火灾、盗窃或地震灾难时，这些备份磁盘也会被销毁，所存储的磁盘备份也起不到任何容灾功能。

真正的数据容灾就是要避免传统冷备份所具有的先天不足，它能在灾难发生时，全面、及时地恢复整个系统。容灾系统按其容灾能力的高低可分为多个层次。例如，国际标准SHARE 78定义的容灾系统有7个层次：从最简单的仅在本地进行磁盘备份，到将备份的磁盘存储在异地，再到建立应用系统实时切换的异地备份系统，恢复时间也可以从几天到小时级到分钟级、秒级或零数据丢失等。无论是采用哪种容灾方案，没有备份的数据，任何容灾方案

都没有现实意义。但是光有备份数据也是不够的，容灾系统也必不可少。

在建立容灾备份系统时会涉及多种技术，主要有：远程镜像技术、快照技术、互联技术和虚拟存储等。

1. 远程镜像技术

远程镜像技术在主数据中心和备援中心之间的数据备份时用到。镜像是在两个或多个磁盘或磁盘子系统上产生同一个数据的镜像视图的信息存储过程，一个叫主镜像系统，另一个叫从镜像系统。按主从镜像存储系统所处的位置又可分为本地镜像和远程镜像。本地镜像的主从镜像存储系统处于同一个 RAID 阵列内，而远程镜像的主从镜像存储系统通常是分布在跨城域网或广域网的不同节点上的。

远程镜像又称远程复制，是容灾备份的核心技术，同时也是保持数据同步和实现灾难恢复的基础。它利用物理位置上分离的存储设备所具备的远程数据连接功能，在远程维护一套数据镜像，一旦灾难发生时，分布在异地存储器上的数据备份并不会受到波及。远程镜像按请求镜像的主机是否需要远程镜像站点的确认信息，又可分为同步远程镜像和异步远程镜像。

然而，远程镜像软件和相关配套设备的售价普遍偏高，而且，得占用两倍以上的主磁盘空间。另外，除了价格昂贵之外，远程镜像技术还有一个致命的缺陷：无法阻止系统损坏和数据丢失、损坏及误删除等灾难的发生。如果主站数据丢失，备份站点上的数据也将出现连锁反应。并且，远程镜像技术还存在无法支持异构磁盘阵列和内置存储组件、支持软件种类匮乏、无法提供文件信息等诸多缺点。

2. 快照技术

远程镜像技术往往同快照技术结合起来实现远程备份，即通过镜像把数据复制到远程存储系统中，再用快照技术把远程存储系统中的信息复制到远程的磁盘中。

从具体的技术细节来讲，快照是通过软件对要备份的磁盘子系统的数据快速扫描，建立一个要备份数据的快照逻辑单元号 LUN 和快照 Cache，在快速扫描时，把备份过程中即将要修改的数据块同时快速复制到快照 Cache 中。快照 LUN 是一组指针，它指向快照 Cache 和磁盘子系统中不变的数据块。在正常业务进行的同时，利用快照 LUN 实现对原数据的一个完全的备份。它可使用户在正常业务不受影响的情况下，实现提取当前在线业务数据。其“备份窗口”接近于零，可大大增加系统业务的连续性，为实现系统真正的 7×24 小时运转提供了保证。快照通过内存作为缓冲区（快照 Cache），由快照软件提供系统磁盘存储的即时数据映像，它存在缓冲区调度的问题。

快照的作用主要是能够进行在线数据恢复，当存储设备发生应用故障或文件损坏时可以进行及时数据恢复，将数据恢复成快照产生时间点的状态。快照的另一个作用是为存储用户提供了另外一个数据访问通道，当原数据进行在线应用处理时，用户可以访问快照数据，还可以利用快照进行测试等工作。因此，所有存储系统，不论高中低端，只要应用了在线系统，那么快照技术就是其不可或缺的功能。

3. 互联技术

早期的主数据中心和备援中心之间的数据备份，主要是基于 SAN 的远程复制（镜像），即通过光纤通道 FC，把两个 SAN 链接起来，进行远程镜像。当灾难发生时，由备份数据中心替代主数据中心保证系统工作的连续性。这种远程容灾备份方式存在一些缺陷，如实现成本高、设备的互操作性差、跨越的地理位置短等，这些因素阻碍了它的进一步推广和实用。

4. 虚拟存储

虚拟存储技术在系统弹性和可扩展性上开创了新的局面。它将几个 IDE 或 SCSI 驱动器等不同的存储设备串联为一个存储池。存储集群的整个存储容量可以分为多个逻辑卷，并作为虚拟分区进行管理。存储由此成为一种功能而非物理属性，而这正是基于服务器的存储结构存在的主要限制。

虚拟存储系统还提供了动态改变逻辑大小的功能。事实上，存储卷的容量可以在线随意增加或减少，可以通过在系统中增加或减少物理磁盘的数量来改变集群中逻辑卷的大小。这一功能允许卷的容量随用户的即时要求动态改变。另外，存储卷能够很容易改变容量、移动和替换。安装系统时，只需为每个逻辑卷分配最小的容量，并在磁盘上留出剩余的空间。

存储虚拟化的一个关键优势是它允许异质系统和应用程序共享存储设备，而不管它们位于何处。

9.3 云计算技术

当前，物联网、大数据等应用快速的发展对系统计算和数据管理带来了新的要求，云计算（cloud computing）作为一种新的共享基础资源的技术和商业模式，具备了高效率计算能力和海量数据管理，提供了一种解决新需求的有效方案。本节从云计算概念及特点出发，介绍典型的云计算体系架构，以及当前云计算数据管理中的主要技术。

9.3.1 云计算概述

1. 云计算的概念

2006 年，谷歌公司在“Google101 计划”中第一次提出云计算概念和理论，指出云计算是继分布式计算（distributed computing）、并行计算（parallel computing）和网格计算（grid computing）之后的一种新的商业计算模式。此后，各研究机构从不同的角度对云计算进行了不同的定义。

IBM 技术白皮书中的定义：云计算一词描述了一个系统平台或一类应用程序；该平台可以根据用户的需求动态部署、配置、重新配置及取消服务等；云计算是一种可以通过互联网进行访问的可扩展的应用程序。

Berkeley 白皮书中的定义：云计算包括互联网上各种服务形式的应用及数据中心中提供这些服务的软硬件设施。互联网上的应用服务一直被称为软件即服务（Software as a Service，SaaS），而数据中心的软硬件设施就是云。

ISO/IEC JTC1 和 ITU-T 组成的联合工作组的国际标准 ISO/IEC 17788《云计算词汇与概述》DIS 版中的定义：云计算是一种将可伸缩、弹性、共享的物理和虚拟资源池以按需自服务的方式供应和管理，并提供网络访问的模式。云计算模式由关键特征、云计算角色和活动、云能力类型和云服务分类、云部署模型、云计算共同关注点组成。

美国标准计算研究院（National Institute of Standards and Technology，NIST）对云计算的定义是：云计算是一种计算模式，它以一种便捷的、通过网络按需接入到一组已经配好的计算资源池，如网络、服务器、存储、应用程序和服务等。在这种模式中，计算资源将以最小的管理和交互代价快速提供给用户。

目前，NIST 对云计算的定义被广泛接受，其给出了云计算的 5 个基本特征、3 种基本服务

模式以及 4 种部署模式，其概念如图 9.4 所示。



图 9.4　NIST 中云计算的概念模型

2. 云计算特征

基于云计算的概念，云计算主要有以下 5 个基本特征。

(1) 广泛网络接入：用户可从任何网络覆盖的地方，使用各种终端设备，如笔记本计算机、智能手机、平板计算机等，随时随地通过互联网访问云计算服务。

(2) 快速弹性架构：服务的规模可快速伸缩，以自动适应业务负载的动态变化。用户使用的资源同业务的需求相一致，避免了因服务器性能过载或冗余而导致服务质量下降或资源浪费。

(3) 资源池化：资源以共享资源池的方式统一管理。利用虚拟化技术，将资源分享给不同用户，资源的放置、管理和分配策略对用户透明。

(4) 按需自服务：以服务的形式为用户提供应用程序、数据存储、基础设施等资源，并可根据用户需求，自动分配资源，而不需要系统管理员的干预。

(5) 可测量的服务：通过监控用户的资源使用量，并根据资源的使用情况对服务计费。通过该特性，可优化并验证已交付的云服务。这个关键特性强调客户只需对使用的资源付费。

3. 云计算分类

按照云计算的服务模式，云计算可分为以下 3 类。

(1) 软件即服务(SaaS)。SaaS 指向用户提供使用运行在云基础设施上的某些应用软件的能力。用户可使用各种类型终端设备上搭载的“瘦”客户端或程序界面来访问应用。用户不需要管理或控制底层的云基础设施，如网络、服务器、操作系统、存储等，只需要配置某些参数即可。典型的应用有：Salesforce 的客户关系管理系统 CRM、谷歌公司的在线办公自动化软件等。

(2) 平台即服务(Platform as a Service，PaaS)。PaaS 指为用户提供在云基础设施之上部署定制应用的系统软件平台。该平台允许用户使用平台所支持的开发语言和软件工具，部署自己需要的软件运行环境和配置。用户不需要管理或控制底层的云基础设施，底层服务对用户是透明的。典型的代表有：Google App Engine、Microsoft Azure 等。

(3) 基础设施即服务(Infrastructure as a Service，IaaS)。IaaS 指通过虚拟化技术来组织底层网络连接、服务器等物理设备，为用户提供资源租用与管理服务。在使用 IaaS 服务过程中，用户需要向 IaaS 层服务提供商提供基础设施的配置信息，运行于基础设施的程序代码及相关的用户数据。典型的代表有：亚马逊的 Web 服务(包括弹性计算云 EC2、简单存储服务 S3 和结构化数

据存储服务 SimpleDB）、IBM 的蓝云（Blue Cloud）、Sun 的云基础设施平台等。

按照云计算的部署模式，云计算可分为以下 4 类。

（1）公有云（public cloud）：由某个组织拥有，其云基础设施向普通用户、公司或各类组织提供云服务。

（2）私有云（private cloud）：云基础设施特定为某个组织运行服务，可以是该组织或某个第三方负责管理，可以是场内服务（on-premises），也可以是场外服务（off-premises）。

（3）社区云（community cloud）：云基础设施由若干个组织分享，以支持某个特定的社区。社区指有共同诉求和追求的团体，如使命、安全要求、政策或合规性考虑等。与私有云类似，社区云可以是该组织或某个第三方负责管理，可以是场内服务，也可以是场外服务。

（4）混合云（hybird cloud）：云基础设施由两个或多个云（私有云、社区云或公有云）组成，独立存在，但是通过标准的或私有的技术绑定在一起，这些技术可促成数据和应用的可移植性，如用于云之间负载分担的 cloud bursting 技术。

9.3.2 云计算体系架构

本节使用 NIST 给出的云计算参考架构，如图 9.5 所示。该架构给出了云计算中的所涉及的主要角色，活动和功能。通过该图，能促进用户更好地理解云计算中的需求、使用、特点和标准等方面的内容。

如图 9.5 所示，NIST 的云计算参考架构中的主要角色包括：云消费者、云提供商、云审计员、云代理商和云承载商。云消费者直接从云提供商或通过云代理商请求云服务；云承载商为云提供商或云代理商到云消费者的连接和传输服务；云审计员主要完成对云服务实现的功能进行操作和安全性等方面的评估。

该架构给出了云计算中的主要活动和功能，包括服务部署、服务编排、云服务管理、安全和隐私。具体而言，服务部署是选择部署模式，具体的已在 9.3.1 节中进行了介绍；服务编排是为了支撑云提供商对计算资源的安排、协同和管理等行为，对系统组件进行的组合，使其能为云消费者提供服务；云服务管理包括所有和服务相关的、服务管理和操作所必需的功能，这些服务都是云消费者所需的或向其推荐的；安全除了云提供商外，也涉及其他的参与者，如云消费者等；隐私主要强调云提供商应保护个人信息和个人识别信息，包括对这些信息进行安全的、适当的、一致的收集、处理、通信、使用和丢弃。

9.3.3 云数据存储技术

当前，云计算中的数据呈现出海量性、异构型、非确定性、异地备份等特点，因此，需要采用有效的数据管理技术对海量数据和信息分析和处理，从而构建高可用和可扩展的分布式数据存储系统。目前，云计算系统中常用的数据文件存储系统有：谷歌的 GFS（Google file system）和 Hadoop 开发的 GFS 的开源实现 HDFS（hadoop distributed file system）；常用的数据管理技术有谷歌的 BigTable 数据管理技术和 Hadoop 开发的开源数据管理模块 HBase。

1. GFS

GFS 是一个管理大型分布式数据密集型计算的可扩展的分布式文件系统，通过使用廉价的商用硬件搭建系统并向大量用户提供容错的高性能的服务。GFS 将系统的节点分为三类：客户端（Client）、主服务器（Master Server）和数据块服务器（Chunk Server），其体系结构如图 9.6 所示。

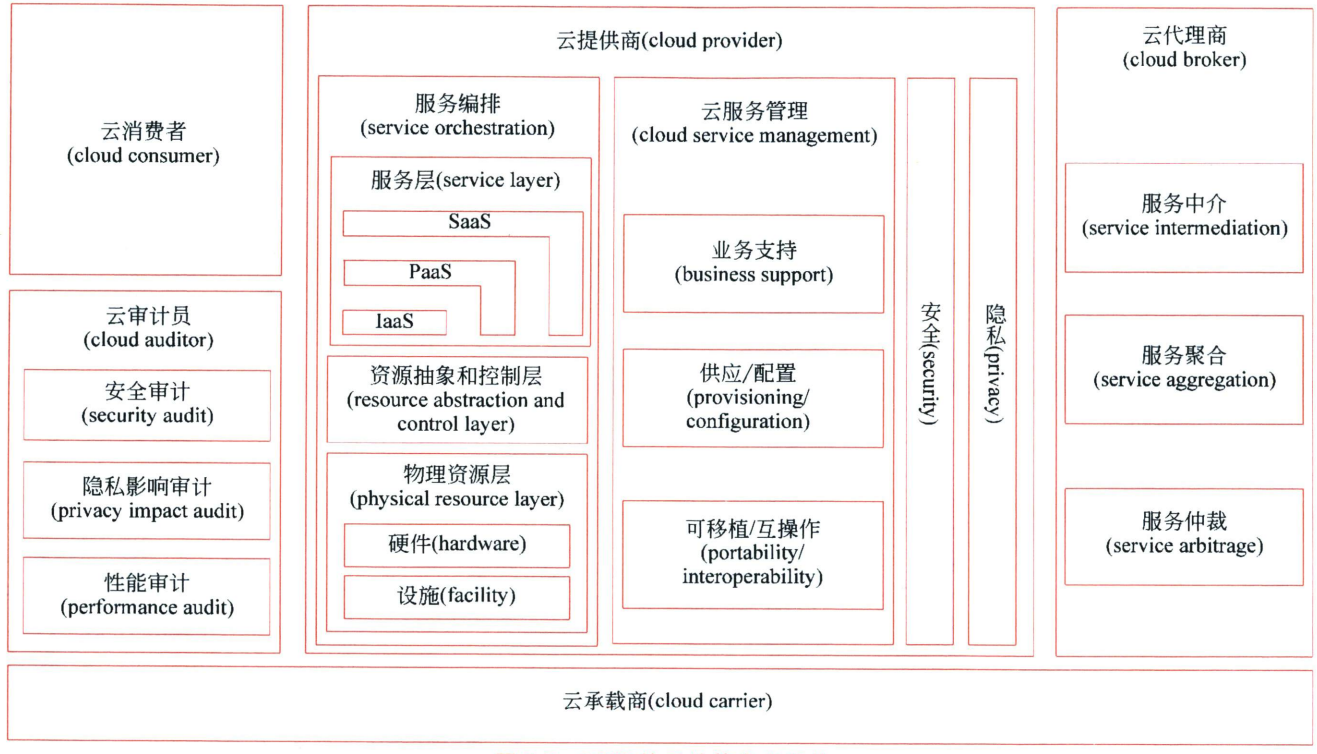


图 9.5　NIST 的云计算参考架构

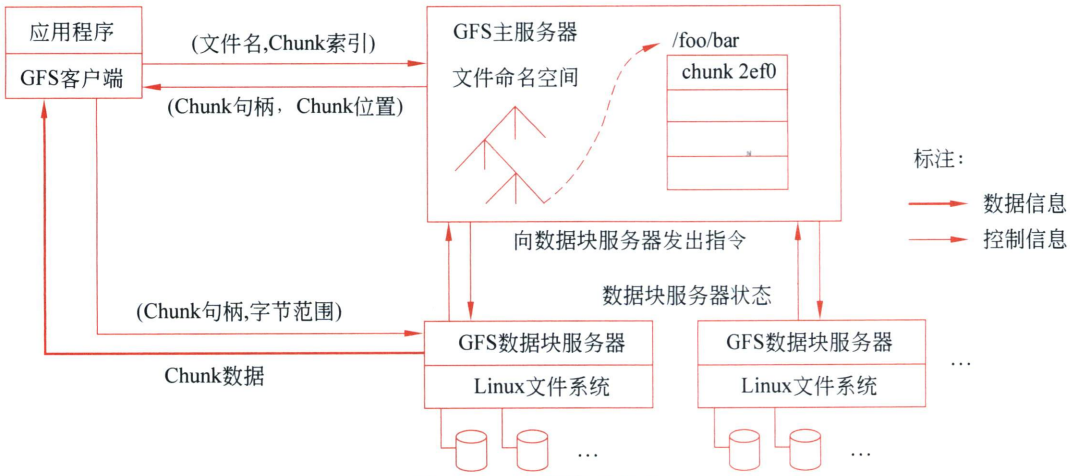


图 9.6 GFS 的体系结构

GFS Master Server 管理所有的文件系统元数据，包括名字空间、访问控制信息、文件和 Chunk 的映射信息，以及当前 Chunk 的位置信息。此外，Master Server 还管理着系统范围内的活动，如 Chunk 租用管理、孤儿 Chunk 的回收及 Chunk 在 Chunk Server 之间的迁移。GFS 存储的文件被分割为固定大小的 Chunk，在 Chunk 创建的时候，Master Server 会给每个 Chunk 分配一个不变的、全球唯一的 64 位的 Chunk 标识。为了提高数据的可靠性，每份数据在系统中保存 3 个以上备份。

客户端在访问 GFS 时，首先访问 Master Server，获取将要与之进行交互的 Chunk Server 信息，然后直接访问这些 Chunk Server 完成数据存取。GFS 的这种设计方法实现了控制流和数据流的分离。Client 与 Master Server 之间只有控制流，而无数据流，这样就极大地降低了 Master Server 的负载，使之不成为系统性能的一个瓶颈。Client 与 Chunk Server 之间直接传输数据流，同时由于文件被分成多个 Chunk 进行分布式存储，Client 可以同时访问多个 Chunk Server，从而使得整个系统的 I/O 高度并行，系统整体性能得到提高。

2. HDFS

HDFS 的设计思想参考了谷歌的 GFS 文件系统，开发了专门针对廉价硬件设计的分布式文件系统，在软件层内置数据容错能力，可应用于云存储系统的创建开发，其体系结构如图 9.7 所示。

HDFS 采用主从(Master/Slave)式架构，包含三个重要的角色：NameNode、DataNode 和 Client。Client 是需要获取分布式文件系统文件的应用程序。

NameNode 作为中心服务器，是 HDFS 中的管理者，主要负责管理文件系统中的命名空间和特定 DataNode 的映射，同时管理用户对文件进行打开、关闭、重命名文件等访问操作。在 NameNode 上，文件系统的 Metadata 存储于内存中，Metadata 中包含了文件信息、文件对应的文件块的信息和文件块在 DataNode 中的信息等。

DataNode 用来存储数据。在 HDFS 中，需要将存储的文件分成一个或多个数据库，存储在多个 DataNode 上。DataNode 是保存文件数据的基本单元，文件的数据块就存储于 DataNode 的本地文件系统中。DataNode 同时保存数据块的元数据，并将所存储的数据块信息周期性地发给 NameNode。DataNode 接收并处理来自分布式文件系统 Client 的读写请求，并在 NameNode 的统一调度下创建、删除和复制数据块。

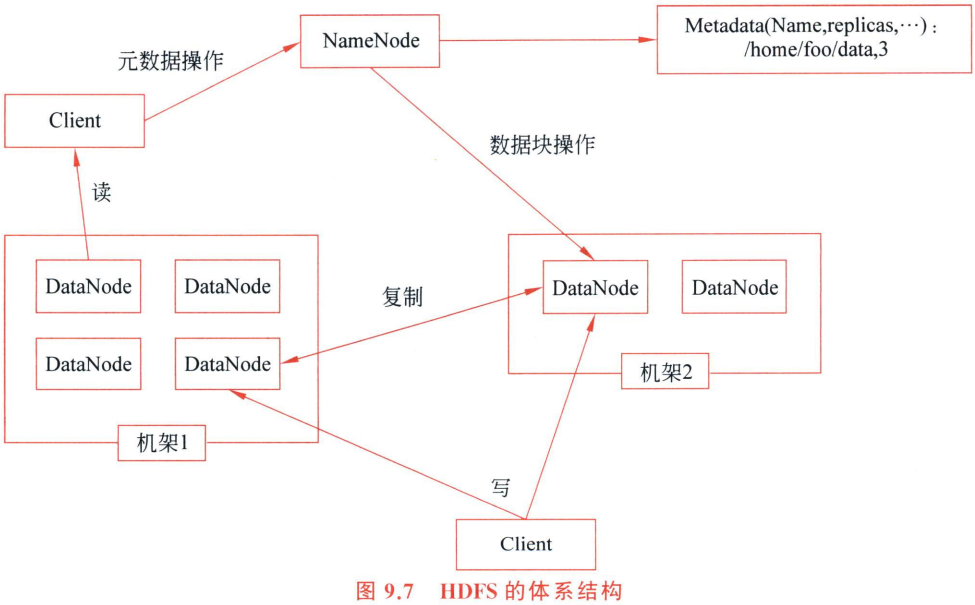


图 9.7　HDFS 的体系结构

9.3.4　云数据管理技术

当前，常见的云数据管理技术有谷歌的 BigTable、Hadoop 的 HBase 等。这里以 BigTable 为例进行简单介绍。BigTable 是建立在 GFS、Scheduler、LockService 和 MapReduce 之上的一个大型的分布式数据库，它将所有数据都作为对象来处理，形成了一个巨大的表格，用来管理结构化数据。谷歌对 BigTable 的定义为：一种为了管理结构化数据而设计的分布式存储系统，其被设计成可以扩展到 PB 的数据和上千台机器。

BigTable 的数据模型是一个稀疏的、分布式的、持续的多维度排序 Map，Map 由 key 和 value 组成，其通过行关键字、列关键字和时间戳实现数据检索功能，因而其存储结构可表示为：(row：string，column：string，time：int64)→string。

BigTable 是在谷歌的其他基础设施之上构建的，其包括 3 个主要的组件：一个主服务器、多个子表服务器和连接到客户程序中的库。主服务器主要负责：管理元数据并处理来自客户端关于元数据的请求；为子表服务器分配表；检查新加入的或过期失效的子表服务器；对子表服务器进行负载均衡等。子表服务器主要用于存储数据并管理子表，每个子表服务器都管理一个由上千个表组成的表的集合，并负责处理子表的读写操作，当表数量过大时对其进行分割操作。由于客户端读取的数据都不经过主服务器，即客户程序不必通过主服务器获取表的位置信息而直接与子表服务器进行读写操作，因而大多数客户程序完全不需要和主服务器通信，从而有效降低了主服务器的负载。

9.4　云计算安全

信息安全管理是一项重要的活动，它致力于控制信息的供应并防止未经授权的使用。安全措施的目的是要保护数据的价值，这种价值取决于机密性、完整性和可用性三方面。根据云数据的部署特点，云数据具有高度可用性、数据冗余性、数据保密性等特性，而且这些特性都与信息安全中的保密性和可靠性相关。因此，为保证云数据的安全问题，就必须要妥善地解决云

计算平台的安全问题，以达到信息安全的五个基本要素的要求，即实现云计算平台的可用性、可控性、完整性、保密性和不可抵赖性。

9.4.1 云计算安全需求

云计算作为一种基于互联网的计算方式，用户数据的隐私保护问题显得尤其突出。在云计算中，由于用户不仅数据完全存储在云端，而且计算过程也全部在云端进行，因此导致了云计算对于用户数据隐私保护比传统的 Web 应用有着更为严峻的形势和更为严格的要求。例如，由于用户的数据存在大量的商业利益，许多黑客以此为攻击目标，在获得用户的数据后将其倒卖获得利益；云计算服务商也往往使用数据挖掘等技术手段，对用户的数据进行统计挖掘，获取用户的行为数据；另外，云服务商中的工作人员由于利益或其他原因，也常常会对存储在云端的数据进行侵犯。而云计算的通用性、虚拟性、共享性等特点，又导致了传统系统中的隐私保护技术往往无法使用在云数据中。调查显示，安全问题一直是云计算中最被人们关注的问题。由此可见，隐私保护问题已经成为阻碍云计算发展的最主要问题之一，不解决云数据的隐私保护问题，云计算的广泛推广与应用将会受到很大阻碍。

在云计算环境下，用户将他们的数据迁移到云计算平台后，数据和信息管理流程将对这些用户不再透明，他们将不再知道自己的数据存储在哪里、被怎么存储的、谁在处理、有没有备份等信息。这个现象同时也是云计算系统中的诸多安全挑战的最主要根源。而且，建立云计算服务提供商和用户之间的信任需要相当长的一段时间，它需要云服务产业链各个环节的企业和组织共同努力，当然，有效地解决上述问题和挑战也是必不可少的。

另外，随着云计算规模的不断扩大，越来越多具有不同属性、不同权限的用户开始使用云计算，数据资源的安全共享也变得越来越困难。面对众多不同属性的用户，如何在云计算中实现数据资源的安全共享也成为一大难题。在云计算中，不同权限的用户在共享某一数据资源时，因为用户的权限不同，它所得到数据资源的内容也不同。但是，传统的安全机制在云计算中难以保证数据资源的这种安全共享，因此，基于云计算的安全共享机制也成为研究的一大热点。

9.4.2 云计算安全威胁

云计算给互联网带来了颠覆性的变化，但是云计算的安全和云计算的发展却不能相提并论。不可否认云计算给 IT 带来的福利，但同时引发了新的安全问题。下面将分别从网络架构的角度和云计算的数据风险来列举云计算数据资源所面对的安全威胁。

9.4.2.1 云计算网络层面的数据安全风险

因为私有云的所有者不需要与其他组织或企业共享任何资源，私有云是企业或组织专有的计算环境，因此，不需要考虑这种新模式所带来的新漏洞或特定拓扑结构的危险变化。所以这里主要讨论云计算模式给公有云带来的数据安全威胁，主要包括以下四方面。

(1) 确保服务提供商传输数据的保密性及完整性。由于公有云需要对外部用户提供相关资源和开发所需服务，那么公有云中的数据资源会面对来自网络外部的访问。2008 年 12 月的亚马逊 Web 服务(AES)漏洞是第一个该方面被发现的安全威胁。

另外，在云计算系统中，计算节点之间的互联互通往往会跨越非安全的公共网络，因此在数据传输过程中面临着窃听、篡改、损毁等各种风险。从原理上说，若要保证数据传输的安全则需要保证在发包端、收包端和包传输全过程三方面的安全。对于发包和收包的终端来说，可

以通过基于终端的安全措施来保护数据传输在发送和接收过程中的安全性，如安全输入输出、内存屏蔽、存储密封等。云计算系统中节点之间的安全数据传输可以通过加密隧道技术保证数据传输的机密性，通过数字摘要、数字证书和数字时间标签来保证数据的完整性和不可篡改性。

(2) 确保服务提供商对所有的资源都提供适当的访问控制，包括审计、认证和授权。由于部分资源(甚至全部资源)暴露在公有云中，对云计算服务提供商的审计、监控变得相当困难。同时，数据在公有云中会接受所有用户的访问申请，如果用户访问到不属于自己的数据就会泄露别人的隐私，因此，服务提供商需要对数据资源进行适当的访问控制，每个用户只能访问到自己拥有的数据，而不能跨用户访问。

(3) 确保云计算中的公有云资源具备可用性。众多的用户数据和资源被公开在公有云上，如何保证所有合法用户能正常访问服务提供商的数据资源成为云计算安全的关注点之一。拒绝服务攻击(DoS)和分布式拒绝服务攻击(DDoS)就是两种严重破坏资源可用性的网络攻击。

(4) 使用域管理来代替现有的网络层面模型。随着云计算的发展，传统网络区域的概念逐渐被取代，云计算中的基础设施即服务(IaaS)和平台即服务(PaaS)将不再按照传统网络层来进行划分。域成为云计算网络管理的一个重要措施。域具有排他性，只允许特定角色访问该指定的区域。同理，域管理下的数据根据其自身所处位置的不同只能访问特定层面的数据。包括建立在 IssS 和 PaaS 基础上的 SaaS，都具备上述域管理的特点。

因此，传统意义上的网络层逐渐通过云计算环境中的安全域进行逻辑隔离。但是与传统隔离不同，不同层的系统在主机层面上不一定是物理隔离的，公有云只是针对不同的系统提供了逻辑隔离。

9.4.2.2　云计算主机层面的数据安全威胁

云计算中的主机层面目前没有碰到有针对性的新威胁，但是虚拟化技术的引入给公有云计算环境带来了主机方面的安全风险。并且，云计算提供的服务模式需要服务提供商能够及时迅速地配置虚拟机资源，以及实现实时的动态迁移，因此，及时更新主机的漏洞补丁也开始变得困难。

此外，云计算资源包括了成千上万台主机，包括虚拟机和硬件服务器，并且这些主机在同一个云计算环境中会使用相同的系统配置，这意味着云计算中存在“高速攻击”的风险，攻破主机系统的风险被放大化。

1. SaaS 和 PaaS 的主机安全

黑客容易利用云计算平台中的主机、操作系统信息来入侵云计算服务提供商的云计算平台。但是由于数据资源共享机制，IaaS 和 PaaS 中的用户对主机安全变得不敏感，大多数的主机安全任务仍由云计算服务提供商来承担。

为了防止主机服务器相关信息的泄露，云计算服务提供商在云计算平台中采用逻辑上的抽象分层技术来加强对云计算用户的管理。但 SaaS 和 PaaS 有一些明显的区别：SaaS 用户不能访问到主机系统的任何信息，实现了完全的逻辑隔离；然而，PaaS 的用户可以通过服务提供商开放的 PaaS 平台接口访问到部分关于服务器的信息。

总之，SaaS 和 PaaS 的用户和服务提供商的合作者只要做好对云计算平台的安全审核就可以确保主机服务器的安全，而不需要亲自花费精力和金钱来确保平台的安全。

2. IaaS 的主机安全

为了实现云计算数据资源的共享，虚拟化技术是一个至关重要的因素，这方面的技术包括 VMware 和 Xen 等。所以虚拟化技术的安全也是 IaaS 的安全因素之一。

从云计算平台的角度来看，云计算系统最基本的单元就是虚拟机。当一个数据文件初次存储到云计算系统中时，它会被分割成若干个碎片并存储在不同的虚拟机上，并在各个虚拟机上面并行地完成对文件碎片的操作。这个文件分割、存储和计算管理的全流程都是由云计算平台来负责的。来自不同公司的重要数据和文件可能会被存储在同一个虚拟机上，因此数据隔离和数据保护就显得非常重要了。虚拟机本身往往会附带一系列的数据管理系统，可以实现一定的数据加密、数据访问控制和数据隔离功能。除此之外，虚拟防火墙可以实现针对单个虚拟机设置安全策略和访问控制策略。最后，云计算系统中的虚拟机可以被分成若干组，并配置不同的安全级别，如不同的加密强度、数据备份、数据恢复设置。用户数据在初次存储到云计算系统中的时候，系统可以根据用户的服务级别将用户数据存储在不同的虚拟机组中以实现服务分级和安全保护分级。

9.4.2.3 云计算应用层面的数据安全威胁

应用或软件安全是云数据安全解决方案的关键，但大多数安全方案都没有充分考虑到应用层面的安全问题。应用程序包括从单机单用户到复杂的有几百万用户的多用户，现阶段的网络应用程序就是多用户应用程序的典型实例，如客户关系管理系统（Customer Relationship Management，CRM）、Wiki、门户网站、论坛、社交网络（Social Network，SN）。很多企业也开始利用不同的网络框架（PHP、.NET、J2EE、Ruby on Rails、Python）开发和维护一些网络应用程序。目前，网络漏洞攻击快速增长、多种新的网络渗透方法涌现，促使云计算模式中的网络应用程序应该受到严格的安全管理。

此外，云计算软件服务提供商通过基于 Web 的“瘦”客户端为用户提供鉴权、登录和应用是云计算软件服务商非常常见的场景。但由于 Web 浏览器本身的脆弱性，Web 应用程序会很容易被植入恶意代码而给用户和服务提供商带来损失。Web 应用程序防火墙可以良好地防范一些基于 Web 的常见攻击，如跨网站脚本攻击、SQL 注入等。

9.4.3 云计算安全技术

为了给云用户提供全面的数据安全保护，用户与云之间的双向身份认证、针对云计算环境各层服务的安全机制等均是必须要考虑的关键技术。下面将针对这几种关键技术进行详细的叙述和分析。

1. 以数据安全为主要目标的云安全架构

目前，由于数据安全和隐私保护是用户最为担心的云安全问题，已有研究者提出以数据安全保护为主要目标的云安全架构。

一种数据安全保护机制架构是 DSLC（data security life cycle），需要管理策略、关键技术、监控机制来共同保障，该架构对云中数据进行保护的思路分为三个步骤：第一步，获得云中数据的存储、传输、处理的相关信息，这样做是由于数据在不同云服务中的表现形式有所不同；第二步，建立数据安全生命周期，包括创建、存储、使用、共享、归档和销毁 6 个阶段；第三步，对数据安全生命周期中的每个阶段均明确数据安全保护机制，将行为实施者（可以是用户、用户、系统/进行等）对数据的操作定义为 functions，而安全机制则定义为 controls，将所有可能的行为限制在允许的行为范围内。DSLC 存在的局限性是与云计算的体系结构联系不够紧密，安全

机制针对性不强。

2. 云计算中的身份认证技术

在云计算中，用户可能使用不同云服务商提供的服务，从而拥有不同的标识符，很容易造成混淆与遗忘。因此，采用联合身份认证技术实现跨云的服务访问，要求在服务访问过程中能够协调各个云之间的认证机制。公钥基础设施 PKI 能根据特定人员或具有相同安全需求的特定应用提供安全服务，包括数据加密、数字签名、身份识别及所必需的密钥的证书管理等。因此，基于 PKI 的联合身份认证技术被广泛用于云中。

虽然 PKI 能够使得依赖方(即云服务提供者)方便地验证用户的证书，但面临巨大的用户群，由于用户所归属的信任域众多，用户和服务商的信任关系也在动态变换，PKI 的效率、证书的撤销等成为很大问题，将会使 PKI 系统设计和实现的复杂度迅速增大。为了降低基于证书的 PKI 的实现复杂度，基于身份的加密技术(Identity-Based Cryptography，IBC)被应用到云计算环境下的用户认证，这种方案不使用证书，用户的公钥直接从用户的身份信息提取。

3. 静态存储数据的保护

云提供的存储服务，也称为数据即服务(Data as a Serives，DaaS)，是云计算中基础设施即服务 IaaS 的一种重要形式。借助于虚拟化和分布式计算与存储技术，云存储将廉价的存储介质整合为大的存储资源池，并向用户屏蔽硬件配置、数据分配、容灾备份等细节。用户租用存储资源放置自己的数据，并且可以远程进行访问。云存储中的数据是静态数据，数据的机密性、可取回性、完整性、隐私性、安全问责等均是用户关注的安全问题。

对于数据保密性问题，一种直观的方式是由用户对数据进行加密。由于加密数据检索无法用传统的基于明文关键字检索，因此，密文检索成为一个研究热点。基于安全索引的方法通过为密文关键词建立安全索引，检索索引查询关键词是否存在；基于密文扫描的方法对密文中每个单词进行比对，确认关键词的存在，并统计出现次数。另一种保证机密性的方法通过访问控制机制来实现。由于云服务商拥有管理员权限，用户无法信赖服务商诚实地实施用户定义的访问控制策略，传统的访问控制类手段无法解决这一问题，因此，基于密码学的访问控制策略开始出现。例如，将用户密钥或密文嵌入访问控制树，访问者只有具有树节点所代表的所有属性，才能获得访问权限。

针对数据丢失问题，云服务商会由于商业利益，竭力隐瞒数据丢失事故，因此，对于用户来说，希望能够验证其数据的完整性。如果将数据全部下载来进行验证，通信开销会比较大，因此，利用某种形式的挑战-应答协议被应用到完整性验证算法中，使云用户在取回很少数据的情况下，通过基于伪随机抽样的概率性检查方法，以高置信概率判断云端数据是否完整。

在数据隐私保护方面，用户希望云服务商除了检索结果之外一无所知，不能通过对用户数据的搜集和分析，挖掘出用户隐私。常采用的方法有 k-匿名、l-多样性、差分隐私等。

4. 动态数据的隔离保护

为了保护动态数据的机密性，密文处理技术是一种直接的方法。IBM 研究院 Gentry 利用“理想格”的数学对象构造隐私同态(privacy homomorphism)算法，也称为全同态加密，使人们可以充分地操作加密状态的数据，在理论上取得了一定突破。Sadeghi 将同态加密与可信计算技术相结合，为云用户提供可信的云服务。上述方案虽然实现了理论上的突破，但由于效率问题，距离实际应用很远。如果数据在计算时解密以明文形式驻留在内存中，则机密性和完整性的保护需要依赖其他的安全机制。因此，一些基于策略模型的安全机制常用来保护云服务中的动态数据。

（1）隔离机制：采用沙箱机制对云应用进行隔离。CyberGuarder是一个虚拟化安全保护框架，在操作系统用户隔离方面，它采用了Linux自带的chroot命令创建一个独立的软件系统的虚拟备份。chroot命令可更改根路径到新的指定路径，由超级用户执行此命令，经过chroot后，在新的根目录下，将访问不到旧系统的根目录结构和文件。

（2）访问控制模型和机制：访问控制仍然是云计算系统中的基本安全机制之一，通过访问权限管理来实现系统中数据和资源的保护，防止用户进行非授权的访问。但是，云计算系统具有高度的开放性、动态性和异构性，对数据进行保护时要考虑不同的参与者、安全策略和使用模式等，这些特点对传统的访问控制模型，如强制访问控制（Mandatory Access Control，MAC）、自主访问控制（Discretionary Access Control，DAC）和基于角色的访问控制（Role-Based Access Control，RBAC）提出了新的挑战。

在SaaS应用中，最常用的访问控制模型是RBAC模型，为了解决传统模型在开放、动态环境中的缺陷，研究者进行了改进和发展。由于不同用户安全策略的差异性，为所有用户建立统一的访问控制模型显然不合理。大多数的方案是按用户进行信任域的划分，再解决跨域的访问控制问题。在云计算中，用户和服务商各方既要提供必需的资源以完成用户的任务，又需要保证他们提供的资源不被对方非法利用，上述的场景需要更细粒度的访问控制策略，但在访问控制模型中，一般对权限的设置是允许或禁止，细粒度的访问控制策略会大幅提高模型的复杂度。

（3）基于信息流模型的数据安全保护机制：信息流控制（Informational Flow Control，IFC）通过追踪系统中的数据蔓延过程，允许不可信的代码对机密数据进行访问，并阻止代码将机密数据传播给非授权的主体。IFC比访问控制机制更便于实现细粒度的数据保护，为了将IFC模型用于动态、协作的分布式计算系统中，Mayer等在2000年提出了分布式信息流控制（Decentralized Information Flow Control，DIFC），对主体、标记、安全策略、标记传递规则分别进行描述，并建立它们之间的内在联系。DIFC具有两个突出特点：安全策略由用户自主制定，不需要CA集中授权，这一特点使其适用于用户数量多，用户安全需求复杂的云计算系统；虽然是分散授权，但能够明确策略的执行点，策略执行是由可信的小部分代码实现，易被监控。

5. 防护监测建立

智能终端与通信技术的发展使得网络朝着多元化、大规模方向发展。云计算平台数据的核心价值在于从海量的复杂数据中分析、预测、挖掘，存储有价值的信息，建立一个以数据为中心的社会。但随之而来的网络安全问题、网络攻击问题，是云时代面临的复杂的信息安全问题之一。例如，APT攻击是一个隐蔽能力强、攻击渠道不确定，集合了多种常见攻击方式的综合攻击。一旦出现隐私泄露、机密外泄等数据安全问题，应可通过数据溯源机制，迅速地定位出现问题的环节。

APT攻击一般包括信息侦查、持续渗透、长期潜伏，攻击者会使用技术手段，利用系统程序漏洞对特定目标进行侦查，整个攻击循环有多个步骤。针对攻击问题，可采用沙箱方案、异常检测、全流量审计、攻击溯源等方法，快速发现攻击源。同时应建立一种新的安全思维，全面采集行为记录，避免内部监控盲点，及时发现潜在的威胁，对数据进行分类，加强应对威胁的能力。

根据检测原理，目前常用的安全检测技术有审计追踪、入侵检测、漏洞检测等，可对系统的运行状态进行监视，收集内容包括数据、用户活动状态，可以及时发现被黑客利用的漏洞，保证系统资源的完整性、机密性、可用性。为保证信息系统的安全，需要采用事前、事后检测、追查、

报警功能的安全检测，提高信息安全基础结构的完整性。

6. 隐私保护的数据分割技术

采用数据分割技术对大数据进行保护。为了保护敏感数据，将整体的数据分割成若干可以独立管理并以清晰的形式存储而不需要引用存储在不同位置的其他数据，如图 9.8 所示。在这种方法中，入侵者无法通过使用单一的片段识别相应的主体，也就无法窃取隐私和重要数据。例如，入侵者窃取的片段包含一个用户名称的数据列表，但是他们无法通过此列表了解任何关于用户名称的其他信息。在保留隐私的数据分割方法中，敏感数据文件被转换为字节，这些字节被组合为一系列的内容。根据数据隐私的优先级，可以使用不同的云来存储部分数据。

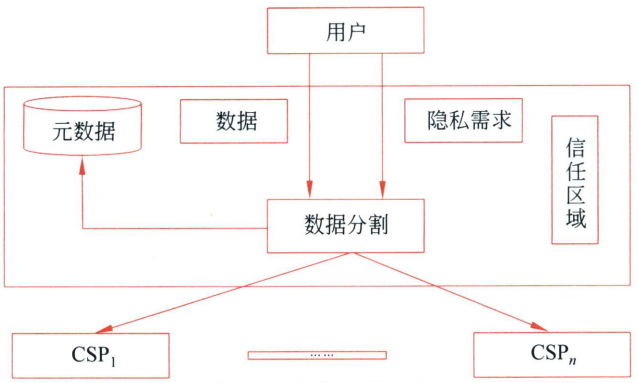


图 9.8　数据分割结构

9.5　本章小结

本章主要从数据备份与恢复、云计算安全两个角度介绍数据安全的相关知识。在数据备份与恢复方面，重点介绍数据备份类型和数据灾备技术；在云计算安全方面，首先介绍云计算相关概念及体系结构，然后分别从云数据存储和云数据管理角度介绍云数据存储管理相关技术；最后介绍当前云计算面临的安全威胁，以及常用的安全保护技术。

思　考　题

1. 什么是数据备份？为什么需要数据备份？其与数据复制有什么不同？
2. 数据备份技术有哪几种分类方式？每种分类方式是如何划分的？各有什么优缺点？
3. 请简述完全备份、增量备份、差分备份这三种备份策略的思路，并说明三种备份方式有哪些不同，各自又有哪些优缺点。
4. 什么是数据容灾？当前主要的数据容灾技术有哪些？
5. 什么是云计算？云计算有哪些主要的特点？
6. 什么是公有云、私有云、混合云？
7. 请说明云计算体系结构中的 SaaS、PaaS、IaaS 的含义及各自的功能。
8. 当前的云存储和管理技术有哪些？请简述其主要思想。
9. 请简述云计算安全面临的安全威胁。
10. 当前解决云计算安全有哪些技术？